Does your dataset contain information that identifies directly a natural person, without the need for additional information?

Yes

No

Have you removed any identifiers (e.g. name, identification number, location data, online identifier or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural orsocial identity ofthat natural person)?

Do you or any third party possess additional information that could help you indirectly link the dataset to a specific natural person? Elements to be taken into account: reasonable likeliness oflinkage, role and capabilities of actors involved, objective factors (e.g. financial cost, amount oftime required for identification, technologies available)

Is the data that you process fall under any ofthese special categories of personal data?

Processing of data could reveal racial or ethnic origin

Processing of data could reveal political opinions

Processing of data could reveal religious or philosophical beliefs

Processing of data could reveal trade union membership

Processing of genetic data

Processing of biometric data for the purpose of uniquely identifying a natural person

Processing of biometric data for the purpose of uniquely identifying a natural person

Processing of health data

Processing of data concerning sex life orsexual orientation

Yes, BUT:

The data subject has given explicit consent to the processing ofthose personal data for one or more specified purposes
except where Union or Member State law provide that the prohibition of processing may not be lifted by the data subject

Processing is necessary for the purposes of carrying out the obligations and exercising specific rights ofthe controller or ofthe data subject in the field of employment and social security and social protection law in so far as it is authorised by Union or Member State law or a collective agreement pursuant to Member State law providing for appropriate safeguards for the fundamental rights and the interests ofthe data subject

Processing is necessary to protect the vital interest ofthe data subject or another natural person where the data subject is physically or legally incapable of giving consent

Processing is carried out in the course ofits legitimate activities with appropriate safeguards by a foundation, association or any other not-for-profit body with a political, philosophical, religious or trade union aim and on condition that the processing relates solely to the members or to former members ofthe body or to persons who have regular contact with it in connection with its purposes and that the personal data are not disclosed outside that body without the consent ofthe data subjects

Processing relates to personal data which are manifestly made public by the data subject

Processing is necessary for the establishment, exercise or defence oflegal claims or whenever courts are acting in their judicial capacity

Processing is necessary for reasons ofsubstantial public interest, on the basis ofUnion or Member State law which shall be proportionate to the aim pursued, respect the essence ofthe right to data protection and provide forsuitable and specific measures to safeguard the fundamental rights and the interests ofthe data subject;

Processing is necessary for the purposes of preventive or occupational medicine, for the assessment ofthe working capacity ofthe employee, medical diagnosis, the provision of health orsocial care or treatment or the management of health orsocial care systems and services on the basis ofUnion or Member State law or pursuant to contract with a health professional and subject to the conditions and safeguards referred to in paragraph 3;

Processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of health care and ofmedicinal products or medical devices, on the basis ofUnion or Member State law which provides forsuitable and specific measures to safeguard the rights and freedoms ofthe data subject, in particular professional secrecy

Processing is necessary for archiving purposes in the public interest, scientific or historical research purposes orstatistical purposes in accordance with Article 89(1) based on Union or Member State law which shall be propor tionate to the aim pursued, respect the essence ofthe right to data protection and provide forsuitable and specific measures to safeguard the fundamental rights and the interests ofthe data subject.

No

Can processing of personal data can be based on any ofthe following?

OR

IF

OR

OR

OR

OR

OR

OR

OR

OR

Yes to at least one ofthe above No

Are data anonymised?

Yes No

Data can be processed Data cannot be processed

OR

IF

OR

OR

OR

OR

OR

OR

OR

GDPR does not apply

No Yes

Have you replaced these identifiers with a code or a token?

Yes

No

Data is pseudonymised

Your dataset contains personal data *Add nuances*

Yes

No

Data are anonymised/anonymous

Your dataset does not contain personal data

Are you established in the EU?

Yes

No

Does the personal data processing concern any ofthe following scenarios?

Is your dataset containing data of natural persons in the EU?

No

Yes

Are your processing activities related to either:

Offering goods orservices to such natural persons, irrespective of any payment requirements?

Monitoring ofthe behaviour ofsuch natural persons, insofar as such behaviour takes place within the EU?

OR

IF

Yes No

Does your processing include personal data relating to criminal convictions and offences or related security measures?

Yes

No

Yes

No

Data cannot be processed

Consent – the data subject has given consent to the processing oftheir personal data for one or more specific purposes Contract – processing is necessary for the performance of a contract to which the data subject is party orin order totake steps at the request ofthe data subject prior toentering intoa contrac Legal obligation – processing is necessary for compliance with a legal obligation to which the controller is subjec Protection of vital interests – processing is necessary in order to protect the vital interests ofthe data subject or of another natural person Public interest / official authority ofthe controller – processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller Legitimate interest – processing is necessary for the purposes ofthe legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms ofthe data subject which require protection of personal data, in particular where the data subject is a child.

IF Is the data subject above 16 years old?

Is it:

Data can be processed

done under the control of official authority?

specifically authorised by the EU or national law?

OR

IF

Yes No

Once it is established that data can be processed lawfully, all ofthe below must be ensured and complied with simultaneously

Determine the purposes and means ofthe data processing?

Process personal data on behalf of another organisation (i.e., data controller)?

Yes OR No

Yes No

Do you:

Is the processing is performed in the course of an activity which falls outside the scope ofEU law?

Is the processing is performed by the EU Member States when carrying out activities which fall within the scope ofthe common foreign and security policy?

Is the processing is performed by a natural person in the course of a purely personal or household activity?

Is the processing is performed by competent authorities for the purposes ofthe prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention ofthreats to public security (law enforcement exemption)?

OR

IF

OR

OR

No

GDPR applies

Yes

You are an independent data controller

IF you have onboarded a data processor, ensure the following: Legal bases for processing personal data

You are a

data processor

Do you determine the means and purposes alone or with others?

Ensure that you are respecting the following obligations:

Alone With others

You are a joint data controller

Ensure that you are respecting the following obligations:

Determination of your respective responsibilities for compliance with the obligations under the GDPR on the basis of an arrangement

Joint Controllers Agreement

Exercise ofrights of data subjects Provision ofinformation under Article 13 and 14 Determination of a data contact point for data subjects (Nice-to-have) Making available ofthe essence ofthe arrangement to the data subject

You have a contract or other legal act under EU or national law, that is binding on you and which includes all the following, including the obligations directly applicable to you:

Records ofProcessing Activities (RoPA) Appointing Data Protection Officer (DPO)

You have a contract or other legal act under EU or national law, that is binding on the processor which includes all the following: You use only processors providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that processing will meet the requirements ofthe GDPR and ensure the protection ofthe rights ofthe data subject.

Data Processing Agreement

Subject-matter and duration ofthe processing, the nature and purpose ofthe processing, the type of personal data and categories of data subjects and the obligations and rights ofthe controller That the processor processes the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or an international organisation, unless required to do so by the EU or national law to which the processor is subject; in such a case, the processorshall inform the controller ofthat legal requirement before processing, unless that law prohibits such information on important grounds of public interest That the processor ensures that persons authorised to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality That the processor takes all measures required pursuant to the security of processing (connection to where we describe Art. 32) That the processor respects the conditions for engaging another processor That the processor is taking into account the nature ofthe processing, assists the controller by appropriate technical and organisational measures, insofar as this is possible, for the fulfilment ofthe controller's obligation to respond to requests for exercising the data subject's rights (connection to where we describe data subjject rights) That the processor assists the controller in ensuring compliance with the obligations pursuant to notification of a data breach to supervisory authority, data subjects, conducting a data protection impact assessment (connections to relevant descriptions) and prior consultations with the supervisory authority, taking into account the nature of processing and the information available to the processor That the processor at the choice ofthe controller, deletes or returns all the personal data to the controller after the end ofthe provision ofservices relating to processing, and deletes existing copies unless EU or national law requires storage ofthe personal data That the processor makes available to the controller all information necessary to demonstrate compliance with the obligations laid down in data processing agreement and allow for and contribute to audits, including inspections, conducted by the controller or another auditor mandated by the controller. Irrespective ofthe terms ofsuch arrangments, joint controllers are jointly and severally responsible forsatisfying data subject requests

Consent requirement from a data controller - the processorshall not engage another processor without priorspecific or general written authorisation ofthe controller. In the case of general written authorisation, the processorshall inform the controller of any intended changes concerning the addition or replacement of other processors, thereby giving the controller the opportunity to object to such changes. Initial processor’s liability and data processing agreement - where a processor engages another processor for carrying out specific processing activities on behalf ofthe controller, the same data protection obligations as set out in the contract or other legal act between the controller and the processorshall be imposed on that other processor by way of a contract or other legal act under EU or national law, in particular providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that the processing will meet the requirements ofthe GDPR. Where that other processor fails to fulfil its data protection obligations, the initial processorshall remain fully liable to the controller for the performance ofthat other processor's obligations.

Data Subject Rights

General requirements for exercising data subject rights

Requirements related to each specific right

Data Security

Have you implemented technical and organisational measures in the following manner? If personal data breach happened at your organisation:

Accountability documents & Data Protection Officer

Data Protection Impact Assessment (DPIA)

International Data Transfers

Do you transfer data to a third country or an international organisation?

AND

Do you ensure that every exercise of data subject rights include all ofthe following?

The following depends on the specific right applicable / request provided by a data subject - not all rights have to be evaluated in each request Right to be informed Right of access Right to rectification Right to be forgotten Right to restriction of processing Right to data portability Right to object Right to not to be subject to a decision based solely on automated processing, including profiling Information is provided in a concise, transparent, intelligible and easily accessible form

AND

Established taking into account (a) the state ofthe art, (b) the costs ofimplementation and (c) the nature, scope, context and purposes of processing as well as (d) the risk of varying likelihood and severity for the rights and freedoms of natural persons.

A level ofsecurity is established appropriate to the risk in particular taking into account protection from accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data transmitted, stored or otherwise processed.

Measures, among others, where appropriate, include:
- the pseudonymisation and encryption of personal data;
- the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services;
-the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;
-a process for regularly testing, assessing and evaluating the effectiveness oftechnical and organisational measures for ensuring the security ofthe processing

Is it unlikely to result in a risk to the rights and freedoms of natural persons?

Is it likely to result in a high risk to the rights and freedoms of natural persons?

BOTH TO BE EVALUATED

No Yes

No

Yes, but: Notification to the supervisory authority No need for notification to the supervisory authority

Without undue delay and, where feasible, not later than 72 hours after having become aware ofit.

TIMING

1. the nature ofthe personal data breach including where possible, the categories and approximate number of data subjects concerned and the categories and approximate number of personal data records concerned;
2. the name the name and contact details ofthe data protection officer or other contact point where more information can be obtained;
3. the likely consequences ofthe personal data breach;
4. the measures taken or proposed to be taken by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects

CONTENT

No need for notification to data subjects Notification to data subjects

without undue delay

TIMING

1. the name the name and contact details ofthe data protection officer or other contact point where more information can be obtained;
2. the likely consequences ofthe personal data breach;
3. the measures taken or proposed to be taken by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects

CONTENT

You have implemented appropriate technical and organisational protection measures, and those measures were applied to the personal data affected by the personal data breach, in particular those that render the personal data unintelligible to any person who is not authorised to access it, such as encryption;

You have taken subsequent measures which ensure that the high risk to the rights and freedoms of data subjects is no longer likely to materialise

It would involve disproportionate effort but you have issued public communication orsimilar measure whereby the data subjects are informed in an equally effective manner.

OR

IF

OR

Yes No

AND

IF

AND

Yes

Data can be processed

No

Data cannot be processed

No Yes

No additional action is needed Is country to which you transfer personal data covered by the European Commission adequacy decision [link to the full list ofthe countries]

No Yes

Can you rely on any ofthe appropriate safeguards? No additional action is needed, data can be transferred

No Yes

Can you rely on any ofthe specific derogiations? Do you have a transfer impact assessment in place following the necessary requirements and the conclusion is positive?

No

Data cannot be transferred

Yes

Data can be transferred

No Yes

Data cannot be transferred Data can be transferred

Do you have 250 or more employees? Is your performed data processing, in particularly using new technologies, and taking into account the nature, scope, context and purposes ofthe processing, likely to result in a high risk to the rights and freedoms of natural persons based on any ofthe following scenarios? Does any ofthe following apply to you?

You are a public authority or body (except for courts acting in their judicial capacity)

Your core activities consist of processing operations which, by virtue oftheir nature, theirscope and/or their purposes, require regular and systematic monitoring of data subjects on a large scale

Your core activities consist of processing on a large scale ofspecial categories of data and personal data relating to criminal convictions and offences.

OR

IF

OR

Yes

You have an obligation to appoint a DPO

No

You do not have an obligation to appoint a DPO

If you decide to appoint a DPO the GDPR DPO requirements apply

A systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural person orsimilarly significantly affect the natural person

Processing on a large scale ofspecial categories of data, or of personal data relating to criminal convictions and offences

A systematic monitoring of a publicly accessible area on a large scale.

Other data processing that may result in high risk to data subjects

OR

IF

OR

OR

Yes

You are obliged to perform a DPIA

No

You are not obliged to perform a DPIA

To perform a DPIA, at least stages 2 and 3 need to be documented as well as means and purposes from stage 1. Additionally, Article 35 ofthe GDPR sets what additionally need to be described in the documented DPIA.

No, but at least one ofthe following applies:

Yes

The processing is not occasional

The processing includes special categories of data or personal data relating to criminal convictions and offences

IF

You are obliged to maintain RoPA

OR

Yes No

You are not obliged to maintain RoPA

Information is provided using clear and plain language

AND

The information is provided in writing, or by other means, including, where appropriate, by electronic means

AND

Information provided without undue delay and in any event within one month ofthe receipt ofthe request (for rights established in Art.15-22)

AND

When personal data are collected from the data subject information about data processing is provided at the time when personal data are obtained

AND

When personal data have not been obtained from the data subject information about data processing is provided:
- within a reasonable period after obtaining the personal data, but at the latest within one month, having regard to the specific circumstances in which the personal data are processed; or
- ifthe personal data are to be used for communication with the data subject, at the latest at the time ofthe first communication to that data subject; or
-if a disclosure to another recipient is envisaged, at the latest when the personal data are first disclosed.

AND

If you do not act on the data subject’s request, you must, without delay and no later than one month after receipt, inform the data subject ofthe reasons and oftheir right to lodge a complaint with a supervisory authority and seek a judicial remedy. Information is generally provided free of charge. Where a data subject’s requests are manifestly unfounded or excessive, particularly because they are repetitive, you may either charge a reasonable fee based on the administrative costs of providing the information or taking the requested action, or refuse to act on the request. You bear the burden of demonstrating the manifestly unfounded or excessive character ofthe request.

AND

OR

AND

OR

AND

Where do you obtain personal data from? Can the provision ofrequested data adversely affect the rights and freedoms of others? The data subject shall have the right to obtain from the controller without undue delay the rectification ofinaccurate personal data concerning them. Taking into account the purposes ofthe processing, the data subject shall have the right to have incomplete personal data completed, including by means of providing a supplementary statement. Does any ofthe following apply? Does any ofthe following apply? The processing: The data subject can object at any time, based on their particularsituation, to your processing carried out for public interest/official authority or your legitimate interests, including profiling. You must stop processing unless you demonstrate compelling overriding grounds or it is necessary for legal claims. Is the automated decision:

Directly from data subject

Not directly from data subject

OR

Does the data subject already has information about data processing?

Does any ofthe following apply? No Yes

The data subject already has information about data processing Information to data subjects must be provided Information to data subjects does not have to be provided

Provision ofsuch information proves impossible or would involve a disproportionate effort or in so far as the provision ofinformation is likely to render impossible orseriously impair the achievement ofthe objectives ofthat processing. You have also taken appropriate measures to protect the data subject's rights and freedoms and legitimate interests, including making the information publicly available

Obtaining or disclosure is expressly laid down by the EU or national law to which the controller is subject and which provides appropriate measures to protect the data subject's legitimate interests

Where the personal data must remain confidential subject to an obligation of professional secrecy regulated by the EU or national law, including a statutory obligation ofsecrecy

OR

IF

OR

OR

Yes

Information to data subjects does not have to be provided

No

Information to data subjects must be provided

No Yes

Information to data subjects must be provided Information to data subjects must not be provided

the personal data are no longer necessary in relation to the purposes for which they were collected or otherwise processed

the data subject withdraws consent and there is no other legal ground for the processing

OR

IF

the data subject objects to the processing

the personal data have been unlawfully processed

the personal data have to be erased for compliance with a legal obligation in EU or national law to which you are a subject

the personal data have been collected in relation to the offer ofinformation society services to a child

OR

OR

OR

OR

Yes

Is the further processing necessary:

No

Requested data must be deleted Requested data should not be deleted

for exercising the right offreedom of expression and information

to comply with legal obligations under EU or national law, or to carry out a task in the public interest or under official authority granted to you.

for reasons of public interest in the area of public health

for archiving purposes in the public interest, scientific or historical research purposes orstatistical purposes

for the establishment, exercise or defence oflegal claims.

OR

IF

OR

OR

OR

No Yes

The accuracy ofthe personal data is contested by the data subject, for a period enabling you to verify the accuracy ofthe personal data

The processing is unlawful and the data subject opposes the erasure ofthe personal data and requests the restriction oftheir use instead

You no longer need the personal data for the purposes ofthe processing, but they are required by the data subject for the establishment, exercise or defence oflegal claims

The data subject has objected to processing pending the verification whether your legitimate grounds of override those ofthe data subject.

OR

IF

OR

OR

Yes

Requested processing must be restricted

No

Requested processing does not have to be restricted

If you restrict processing, you may only store the data and otherwise process it only with the data subject’s consent, for legal claims, to protect others’ rights or for important public interest under the EU or national law.

You also need to inform data subject before the restriction is lifted

Is based on consent or contract

is carried out by automated means

AND

IF

Yes

Can the provision ofrequested data adversely affect the rights and freedoms of others?

No

Information to data subjects does not have to be provided

No Yes

Information to data subjects must be provided Information to data subjects cannot to be provided

Data subject shall have the right to have the personal data transmitted directly from one controller to another, where technically feasible.

necessary for entering into, or performance of, a contract between the data subject and a data controller?

authorised by the EU or national law to which you are the subject and which also lays down suitable measures to safeguard the data subject's rights and freedoms and legitimate interests?

based on the data subject's explicit consent?

OR

IF

OR

Yes

The right not to be subject to a decision based solely on automated processing does not apply

No

The right not to be subject to a decision based solely on automated processing applies

Ensure that the following conditions are respected:

Ability to demonstrate that the data subject has consented to the processing oftheir data

In case the data subject was called to provide consent in the context of a written declaration concerning other matters, ability to demonstrate that the request for consent was presented:
- in a manner clearly distinguishable from other matters
- in an intelligible and easily accessible form
- using clear and plain language

Possibility for the data subject to withdraw their consent at any given moment Consent is freely given, specific, informed and unambiguous

Re freely given element, consider (among other elements) providing consent to the processing of personal data not necessary for the performance of a contract, was a condition for the performance ofsaid contract

Yes

No

Is consent given or authorised by the holder of parental responsibility over the child?

No

Data cannot be processed

lawfulness, fairness and transparency

personal data shall be processed
processed lawfully, fairly and in a transparent manner in relation to the data subject

purpose limitation

personal data shall be
collected forspecified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes

data minimisation

personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed

accuracy

personal data shall be
accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay

storage limitation

personal data shall be
kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed

integrity and confidentiality

personal data shall be
processed in a manner that ensures appropriate security ofthe personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures

accountability

the controllershall be responsible for and be able to dermonstrate compliance with data protection principles

STAGE 1. ESTABLISHING EXISTENCE OF PERSONAL DATA, THE APPLICABILITY OF THE GDPR AND DATA PROCESSING ROLES STAGE 2. ESTABLISHING THE NATURE OF PERSONAL DATA AND LAWFULNESS OF DATA PROCESSING STAGE 3. COMPLYING WITH OBLIGATIONS UNDER THE GDPR DATA PROTECTION PRINCIPLES - APPLICABLE THROUGHOUT THE CYCLE OF EACH DATA PROCESSING OPERATION